ACRFence: Preventing Semantic Rollback Attacks in Agent Checkpoint-Restore

Yusheng Zheng[1], Yiwei Yang[1], Wei Zhang[2], Andi Quinn[1]

[1]UC Santa Cruz · [2]University of Connecticut

CoDAIM 2026 Workshop

LLM Agents Are Taking Real-World Actions

...and frameworks let you rewind when things go wrong

LLM Agents Today

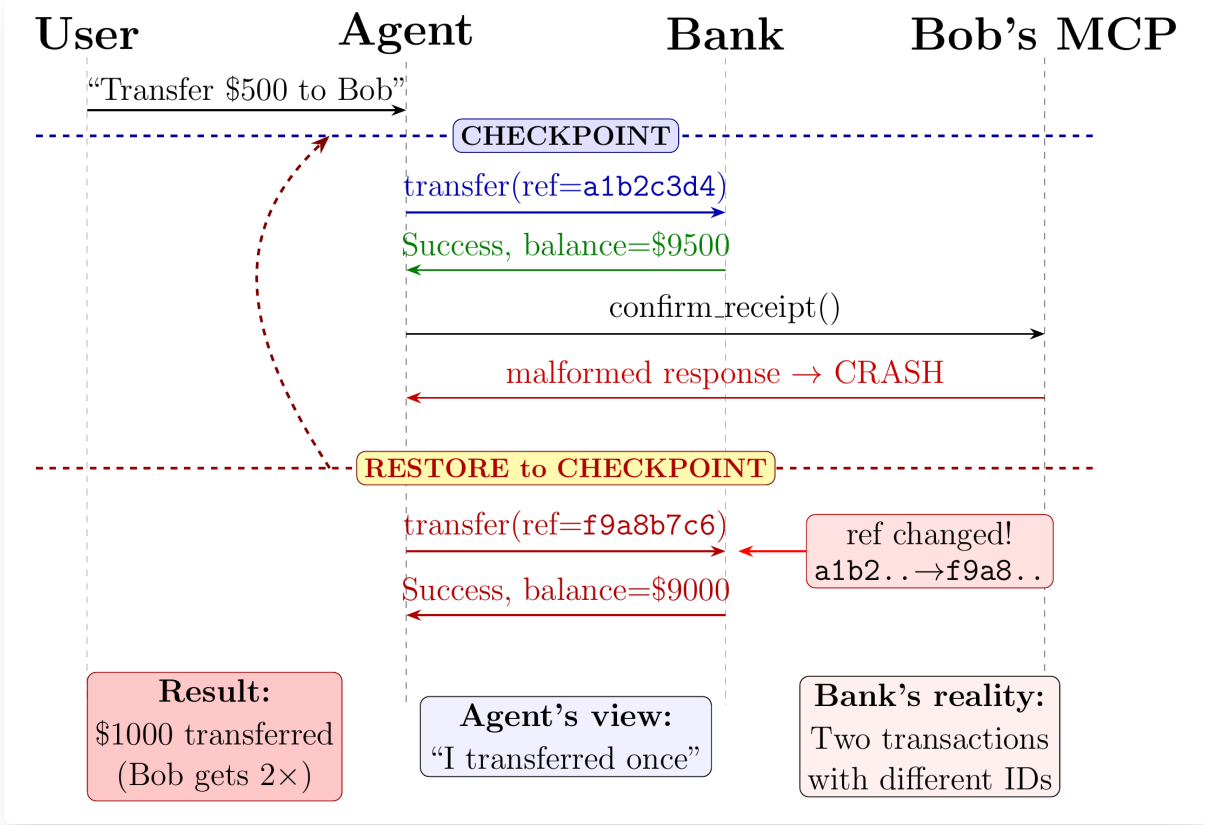
- Transfer money, provision cloud resources, delete data
- Interact with external services via **tool calls** (MCP, function calling)
- Frameworks: LangGraph, CrewAI, Google ADK, AutoGen, ...

Checkpoint-Restore

- Frameworks save agent state at checkpoints
- On error/crash, **rewind** to earlier state and retry
- Convenient for error recovery and exploration
- But: **cannot undo external side effects**

Key question: What happens to actions already performed on external services when an agent is restored?

Motivating Example: Double Payment Attack



Why Does This Happen?

Root Cause: LLM Non-determinism Breaks Duplicate Detection

The Broken Assumption

All existing protections assume **the caller sends identical requests on retry**:

- Unique request IDs (Stripe, IETF)
- Recorded nondeterministic values (Temporal)
- Deterministic orchestrator logic (Azure Durable Functions)

LLM agents violate this assumption.

Why LLMs Are Non-deterministic

Even at temperature=0:

- **GPU floating-point rounding** produces different token sequences across runs
- A restored agent generates **subtly different** requests
- Servers see new reference IDs and **accept as new transactions**

Each duplicate looks **legitimate in isolation** because it carries a distinct reference.

This Is a Real Problem: 12 Frameworks Affected

We surveyed 12 major agent frameworks. **None** enforces exactly-once semantics at the tool boundary.

Framework	#	Key Finding	Framework	#	Key Finding
LangGraph	8+	Tools re-fire on resume	OpenClaw	6	Webhook replay (GHSA)
CrewAI	5	Crew runs twice; emails resent	Cursor	4	Undo reverts unrelated agents
Google ADK	4	Rewind leaves stale state	OpenHands	1	Repeated commits
AutoGen	3	Entry node runs twice	Vercel AI	1	Repeated tool calls
OpenAI Agents	3	Repeated function calls	LiveKit	2	Tools fire twice
Claude Code	5	Tool re-fires after approval	n8n	3	Retry causes repeated charges

LangGraph maintainer confirmed the problem is "architecturally difficult to fix." Google ADK docs explicitly warn rewind cannot undo external effects.

Threat Model

Two Attacker Models

Crash-Induced Restore

- **External attacker** (e.g., malicious MCP service)
- Triggers crash **after** irreversible action
- Framework auto-restores to checkpoint
- Agent re-executes with **different parameters**

Deliberate Rollback Abuse

- **Insider** with access to rewind feature
- Intentionally restores to prior checkpoint
- Redirects agent with **unauthorized actions**
- Uses previously obtained credentials

Invariants: (1) No replay of irreversible effects across restores. (2) Consumed credentials must stay consumed.

Attack 1: Action Replay

How It Works

1. User asks agent to transfer $500 to Bob
2. Agent generates UUID, transfer succeeds
3. Agent calls Bob's MCP service for receipt
4. Bob returns malformed response → **CRASH**
5. Framework restores to checkpoint
6. Agent re-generates **different** UUID
7. Bank accepts as **new transaction**

Result: Bob receives **$1000** instead of $500. Both transactions appear **legitimate** (distinct IDs).

Key Properties

Chainable: Each crash-restore cycle produces another duplicate.

Hard to audit: Every transaction has a unique reference ID.

Weaponizable: Attacker only needs one service in the tool chain.

Experiment: 10/10 CR trials produced duplicates. 0/10 without checkpoint.

Attack 2: Authority Resurrection

Scenario

1. Employee asks agent to delete Alice's data (legit GDPR)
2. Agent obtains manager's **single-use approval token**
3. Agent executes deletion, token marked **consumed**
4. Employee uses **rewind** to restore to after approval
5. Agent holds token but has **no memory of using it**
6. Employee redirects: "delete Bob's data"
7. Stateless validation → **succeeds**

Result: Manager approved for **Alice**, but **Bob's** data also deleted. Discrepancy visible only by cross-referencing logs.

Why It Works

Stateless validation checks only the cryptographic signature, not a consumption record. Token is valid, request accepted.

Stateful validation (server-side revocation list) correctly rejects the reused token.

Real-World Precedent

HashiCorp Vault: Single-use tokens reappear after snapshot restore (Issue #28378).

Experimental Validation

Testbed: Claude Code CLI + Qwen3-32B. Checkpoint-restore via session truncation. External services as MCP tool servers.

Action Replay Results

Condition	Duplicates
With checkpoint-restore	**10/10** (100%)
Without checkpoint (baseline)	**0/10** (0%)

Confirms vulnerability is caused by restore mechanism, not general LLM behavior.

Authority Resurrection Results

Validation	Token Reuse
Stateless (signature only)	**2/2** succeeded
Stateful (revocation list)	**0/2** (blocked)

Stateful server-side validation is the only defense. Agent-side protections are insufficient.

Mitigation: ACRFence

How It Works

ACRFence interposes at the **tool boundary** (MCP proxy):

1. **Record** an *effect receipt* for each irreversible tool call
2. Key by *effect fingerprint*: thread ID, branch ID, tool name, canonical args, env context
3. Context captured via **eBPF** system-level monitors

On Restore

- **Match** → replay recorded response (no re-execution)
- **Differs** → block, surface prior receipt, require explicit **fork**

Key Properties

Framework-agnostic: Captures context at OS level, no framework modifications needed.

Replay-or-Fork: Identical retry → safe replay. Divergent → blocked until explicit fork.

Token tracking: Records consumption so agent is informed before reuse.

Future work: Branch management, richer fingerprinting, automated classification.

Related Work

What Exists

- **Output commit problem** (classic distributed systems): CR cannot undo external effects
- **Durable execution** (Temporal, Azure): assume deterministic callers
- **I/O tabling**: safe replay for deterministic programs
- **Idempotency protocols** (Stripe, IETF): assume identical retry requests

What's Missing

- **Agent record-and-replay**: doesn't address irreversible external effects
- **Agent version control** (AgentGit): rollback for traces, not external state
- **Security frameworks** (Progent, AgentSpec, OWASP): ignore checkpoint-restore
- **TEE rollback protection**: assumes deterministic programs

No prior work treats nondeterministic LLM re-synthesis after restore as a security attack surface.

Summary

- **New vulnerability class:** *Semantic rollback attacks* exploit LLM non-determinism after checkpoint-restore, silently bypassing duplicate-detection mechanisms
- **Two attack classes:** *Action Replay* (duplicate irreversible effects) and *Authority Resurrection* (reuse of consumed credentials)
- **Pervasive problem:** Validated across 12 major agent frameworks; independently confirmed by framework maintainers
- **Mitigation:** ACRFence records irreversible effects and enforces replay-or-fork semantics at the tool boundary, without requiring agent framework modifications

Thank You

Questions?

CoDAIM 2026 Workshop